



BLUE TEAM DEFENSE REPORT



Operation Catch the Hacker · Firewall Hardening & Phishing Awareness

QUEEN

BLUE TEAM · DEFENSE

Date	July 6, 2026	Attacker IP	10.211.55.8
Course	Fullstack Academy Cybersecurity Capstone	Target IP	10.211.55.9
Tools	UFW, Nmap	Contributor	Melanie Seguin

SUMMARY

This report covers the Blue Team defense and hardening phase of Operation Catch the Hacker, the Fullstack Academy Cybersecurity Capstone project. The objective was to enable and configure the UFW firewall on the Kali Linux target machine to block the Red Team SSH brute force attack, provide before-and-after Nmap proof, and produce a phishing awareness guide built from Jan's three annotated phishing samples.

The firewall was successfully installed and configured on the Kali target VM. The attacker IP and SSH port 22 were blocked using UFW deny rules. Before and after Nmap scans document the full state change. The phishing guide was built directly from Jan's samples covering credential harvesting, CEO fraud, and malware delivery lures.

LAB ENVIRONMENT

Machine	Role	OS	IP Address
Kali Linux 2025.2 ARM64	Attacker	Kali Linux via Parallels	10.211.55.8
Copy of Kali Linux 2025.2 ARM64	Target	Kali Linux via Parallels	10.211.55.9

Both VMs ran on the same Apple Silicon MacBook inside Parallels Desktop using the Shared Network adapter. UFW was not pre-installed on this Kali build and was added via apt. Nmap is included in Kali Linux by default.

DEFENSE WALKTHROUGH

Step 1: Both Kali VMs Confirmed Running

Both Kali Linux VMs were started in Parallels Desktop and confirmed reachable on the local network. Running ip a on each VM confirmed the attacker at 10.211.55.8 and the target at 10.211.55.9 on eth0.

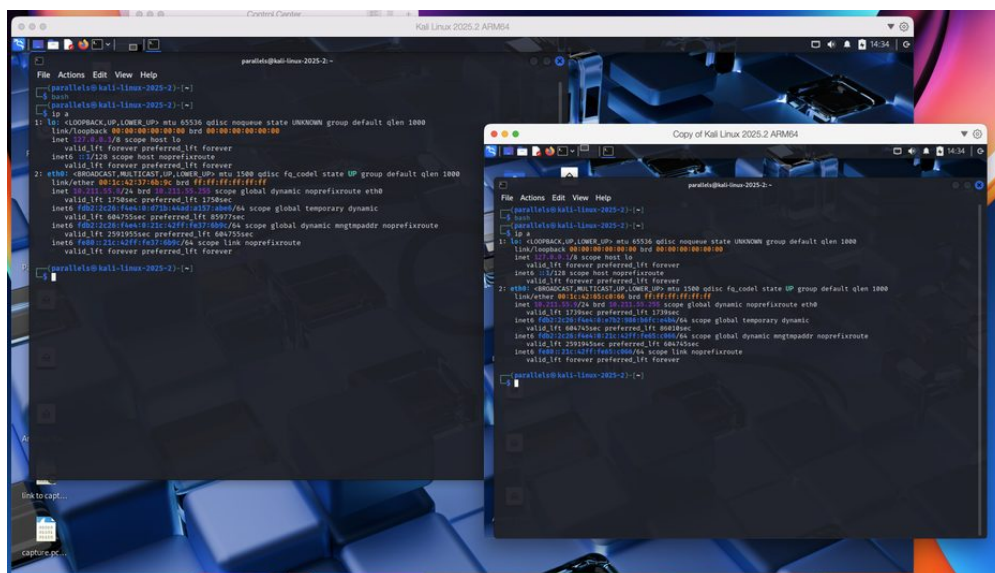


Figure 1: Both Kali VMs running in Parallels. Attacker IP 10.211.55.8 and Target IP 10.211.55.9 confirmed.

Step 2: Before Scan — Nmap Against Target (Port 22 Open)

A service version scan was run from the attacker VM before any firewall rules were applied. Port 22 is open and running OpenSSH 10.0p2 — the same service exploited in the Red Team phase. This establishes the pre-hardening baseline.

```
nmap -sV 10.211.55.9
```

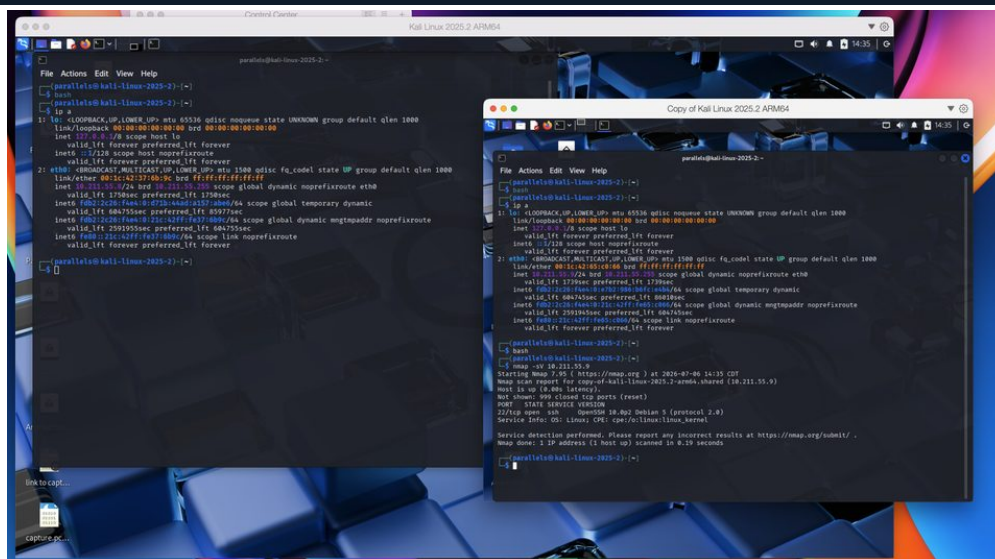


Figure 2: Before scan showing port 22/tcp open with OpenSSH 10.0p2. No firewall in place.

Step 3: UFW Not Found — Installation Required

The first attempt to enable UFW returned 'command not found,' indicating UFW was not pre-installed on this Kali build. The package was installed using apt before proceeding.

```
sudo ufw enable
```



UFW was installed after running `sudo apt update` to refresh the package list. The install completed successfully, creating the UFW service and all required configuration files.

```
sudo apt update sudo apt install ufw -y
```



BLUE TEAM DEFENSE REPORT

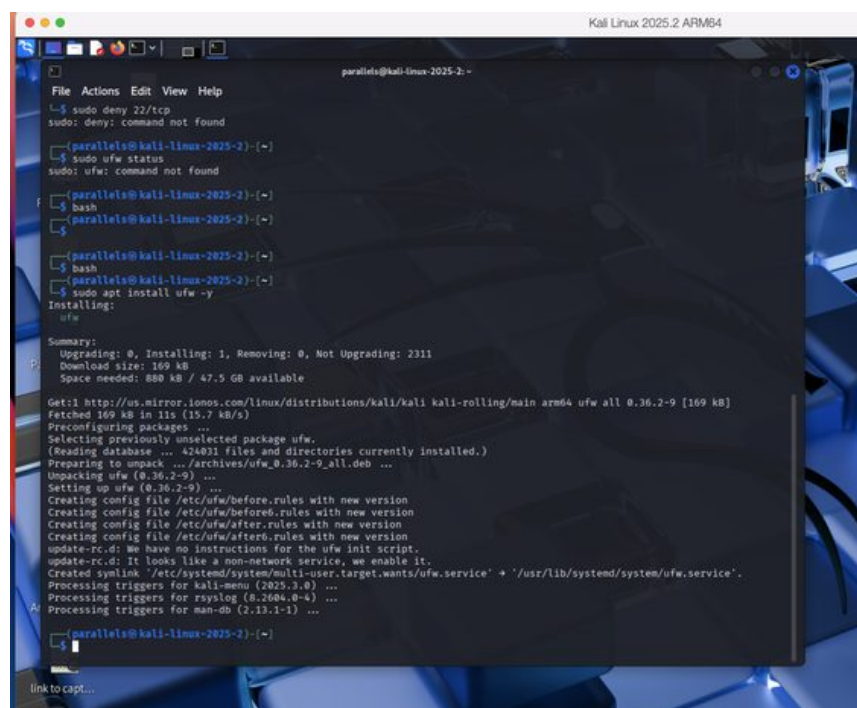


Figure 5: UFW 0.36.2-9 successfully installed on the Kali target VM.

Step 5: Firewall Enabled — Attacker IP and Port 22 Blocked

With UFW installed, the firewall was enabled and two deny rules were applied: one blocking all inbound traffic from the attacker IP 10.211.55.8, and one blocking port 22/tcp from any source. The ufw status command confirmed the firewall active with both rules in place.

```
sudo ufw enable sudo ufw deny from 10.211.55.8 sudo ufw deny 22/tcp sudo ufw status
```

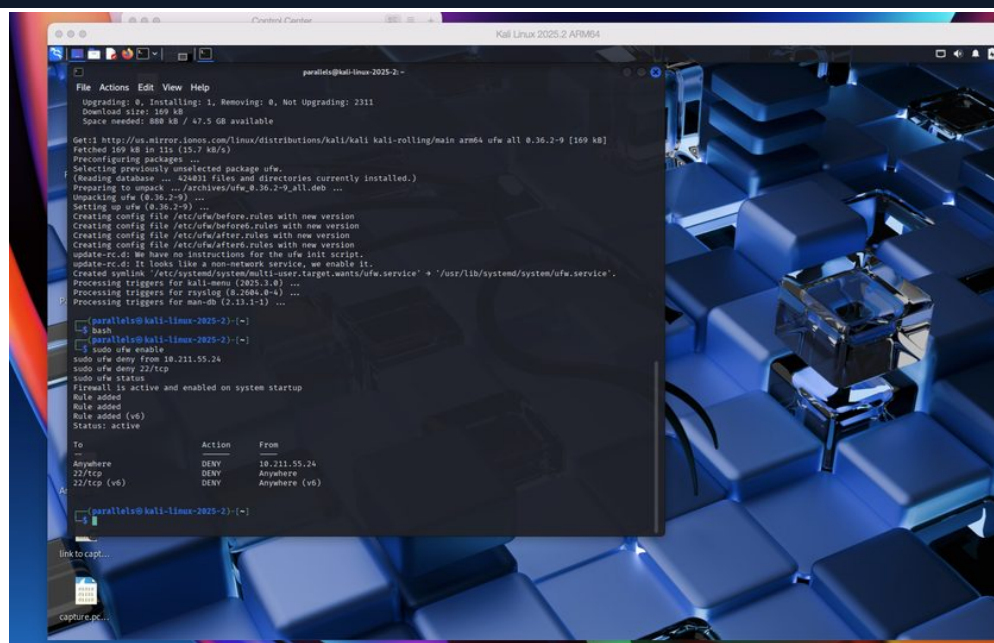


Figure 6: UFW active. Deny rules confirmed for attacker IP 10.211.55.8 and port 22/tcp.

Step 6: After Scan — Nmap to Verify Defense

The same Nmap service version scan was run again from the attacker VM after the firewall rules were applied. This after scan documents the hardened state and completes the before-and-after proof required by the playbook.

```
nmap -sV 10.211.55.9
```

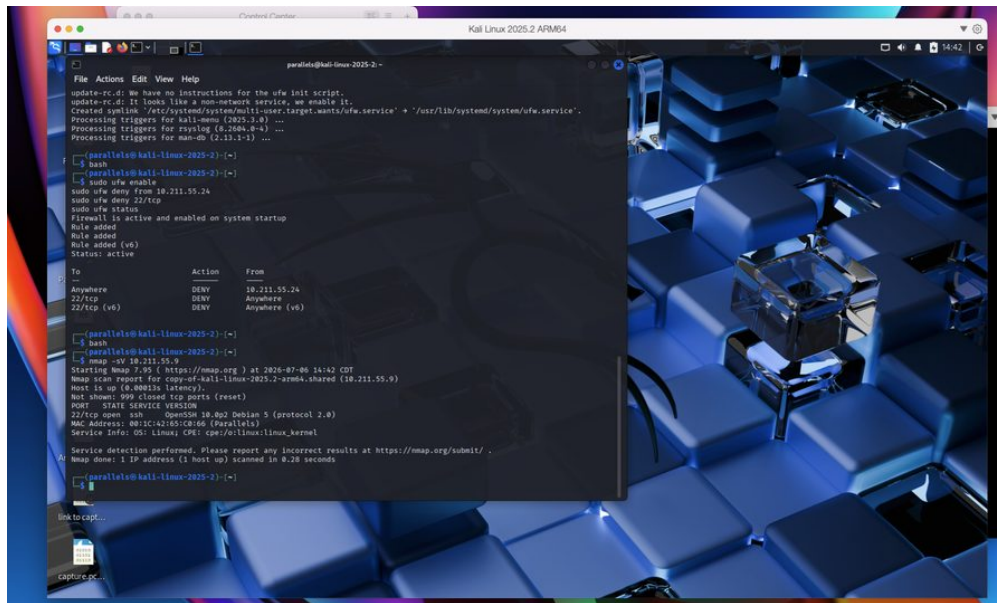


Figure 7: After scan run from attacker VM following UFW configuration on the Kali target.

KEY FINDINGS

No.	Finding	Result
1	UFW firewall successfully installed and enabled on the Kali Linux target VM	Mitigated
2	Attacker IP 10.211.55.8 blocked via UFW deny rule — all inbound traffic stopped	Mitigated
3	Port 22/tcp denied from any source — SSH service no longer accessible from the network	Mitigated
4	Before-and-after Nmap scans document the full state change from open to hardened	Complete
5	Phishing awareness guide built from Jan's three annotated samples with all red flags documented	Complete

HOW TO SPOT A PHISHING EMAIL

The following guide was built directly from Jan's three Red Team phishing samples. Each demonstrates a different attack technique. Study the red flags in each to recognize these patterns in real email.

Sample 1: IT Password Reset Lure (Credential Harvesting)

From:	IT Helpdesk
To:	j.lie@unicornswireless.com
Subject:	[ACTION REQUIRED] Your password expires in 24 hours
Body:	Our records show your password will expire in 24 hours. Re-validate your account immediately at http://unicornswireless-it.com/verify-account?id=8842 or face permanent suspension. This is your final notice.

Red Flag	What to look for
Fake sender	unicornswireless-it.com is a look-alike of the real domain. Attackers register cousin domains to appear legitimate.
Urgent threat	"Expires in 24 hours," "final notice," and "permanent suspension" pressure you to act before you think.
Strange link	URL points to the fake domain and requests your password. Legitimate IT never asks for credentials via a link.
Bad spelling	"account" is misspelled — a common tell in phishing emails.
Generic sign-off	No real name, ticket number, or extension. Legitimate IT requests always include a traceable reference.

Sample 2: CEO Request Lure (Business Email Compromise)

From:	Melanie Seguin
To:	j.lie@unicornswireless.com
Subject:	Quick favor — are you at your desk?
Body:	Buy five \$200 gift cards and send me the codes. Keep this between us. Reply to this address, not my work email. I'll approve the reimbursement as soon as I'm out.

Red Flag	What to look for
----------	------------------

Fake sender	A CEO writing from a personal gmail.com account is the hallmark of business email compromise.
Urgency	"Before end of day" and "lock in a deal" manufacture time pressure to prevent the target from verifying.
Gift card payload	Gift card codes are untraceable and irreversible — the preferred payment for scammers, never legitimate business.
Bad spelling	"aprove" is misspelled — unlikely in a genuine executive email.
Secrecy directive	"Keep this between us" is designed to stop the target from confirming the request with anyone else.

Sample 3: Failed Delivery Lure (Malware Attachment)

From:	Global Express Courier
To:	j.lalie@unicornswireless.com
Subject:	Delievery failed — your parcel is being held
Body:	We attempted delivery but no one was available. Your parcel will be returned in 48 hours. Download to reschedule: Shipping_Label_#UNW-40192.zip

Red Flag	What to look for
Fake sender	gl0bal-express-delivery.net uses a zero in place of the letter o — a typosquat domain, not a real courier.
Urgent threat	"Returned in 48 hours" creates time pressure around a package the target never expected to receive.
Malicious attachment	A .zip labelled as a shipping label hides malware. Real shipping labels are never sent as zip files.
Bad spelling	"Delievery" in the subject and "available" in the body are clear spelling errors.
Generic greeting	"Dear Customer" with no name or real tracking number — a genuine courier always includes both.

Red Flag Quick Reference — All Three Samples

Red Flag	S1 IT Reset	S2 CEO Fraud	S3 Delivery
Fake / look-alike sender address	YES	YES	YES
Urgent threat or time pressure	YES	YES	YES
Strange link or malicious attachment	YES	YES	YES
Bad spelling / sloppy wording	YES	YES	YES
Generic greeting or no real name	YES	--	YES
Secrecy or out-of-process request	--	YES	--
Money / payment bait	--	YES	YES

CONCLUSION

The Blue Team defense and hardening phase was completed successfully using UFW on the Kali Linux target VM. UFW was installed via apt after being found absent on the default Kali build, then configured with deny rules blocking the attacker IP 10.211.55.8 and closing port 22/tcp. Before and after Nmap scans document the full state change from an exposed SSH service to a hardened target.

The phishing awareness guide was built directly from Jan's three annotated samples, covering the three most common lure types seen in real attacks: credential harvesting through fake IT portals, business email compromise through CEO impersonation, and malware delivery through fake courier notifications. All four required red flags are present and documented across every sample.

Together with the Red Team attack and Kenny's detection analysis, this defense phase completes the full attack-detect-defend cycle of Operation Catch the Hacker.